Cyber Security Training (VAPT)

Introduction

→What is Cyber Security? Why is it important?

→Types of Cyber Attacks

- ❖ Man in the Middle Attack
- ❖ Zero-day Exploit
- ❖ DNS Tunneling
- ❖ Cryptojacking
- ❖ XSS attacks
- ❖ Social Engineering
- ❖ DOS and DDOS attack
- ❖ SQL Injection
- ❖ Phishing
- ❖ Malware
- ❖ Ransomware

1.Vulnerability assessment and Penetration Testing

→What is security testing

→What is vulnerability assessment why its required

→What is penetration testing

→ Application Security Assessment

- ❖ Secure Code Review
- ❖ Web Application Security
- ❖ Web Service Security
- ❖ API Security
- ❖ Windows Application Security
- ❖ Mobile Application Security
- ❖ Network Security

→ OWASP Top 10 overview

→ OWASP security testing methodology

→ Report Preparation

2.Secure Code Review

→SAST (Static Analysis Security Testing)

→DAST (Dynamic Analysis Security Testing)

→Scan code using CodeQL in GitHub Advance Security

→what is Dependabot, Code scanning, Secret scanning

→What is Risk Report

→Security Vulnerabilities, Outdated Libraries, Policy Violations, High Risk Medium Libraries

3.Web Application Security

1.Broken Access Control

→Improper Access Control or URL Manipulation or Authentication Bypass
→Privilege Escalation or Session Replay or Broken Authorization
→Insecure Direct Object Reference (IDOR)
→Inadequate Session Management or Session Fixation

2.Cryptographic Failures

→What is cryptographic algorithm
→Encoding and decoding, hashing
→Weak Ciphers or Weak cryptographic algorithms
→Weak Encoding for Password
→Weak Encryption
→Expired SSL certificate
→Clear text Transmission of Sensitive Information

3.Injection

→What is injection & types of injections
→HTML Injection attacks
→SQL injection attacks
→Cross site scripting attacks
→Cross site Request Forgery
→XXE (Xml injection)

4.Insecure Design

→Unprotected Storage of credentials
→External control of path or file name
→Storing passwords in recoverable format
→Unrestricted upload of files
→Use of browser cache containing sensitive information
→Inconsistent interpretation of http requests
→Insufficient input validation
→Insufficient authentication and authorization [Authentication system]
→Improper session management
→Inadequate error handling and information exposure
→Insufficient data storage
→Insecure communication
→No Rate limiting
→Clear text storage of sensitive information in memory

5.Security Misconfigurations

→Using default credentials
→Unencrypted files

→Unprotected files and directories [Directory Listing]
→Web application Misconfiguration
→Password found in response in plaintext format [Cleartext submission of password]
→Error messages showing sensitive information
→Unnecessary features [If website has multiple open ports, services, components, accounts]
→out of date software vulnerability [Unsupported software in use]

6.Vulnerable and outdated components

→Known vulnerable JavaScript library is used
→Application uses vulnerable and outdated components
→Known vulnerable bootstrap library is used

7.Identification and Authentication Failures

→Weak password policies
→Lack of Multi-Factor Authentication (MFA)
→Session management flaws
→Brute Force Attacks
→Session Identifier Exposed in the URL
→2FA Bypass through brute-force

8.Software and Data Integrity Failures

→Related to software updates
→Insufficient Verification of Data Authenticity
→Missing support for integrity checks
→Untrusted search path

9.Security Logging and Monitoring

→Insecure logging and Monitoring systems
→Not monitoring Logs for suspicious activity
→Not storing logs for long enough
→Not logging important security events

10.Server-side Request Forgery

4.Web Service Security

→What is webservice and soap protocol
→what is request and response, xml data
→Important security headers
→ Scan application using web inspect
→ WSDL Enumeration
→ XML External Entity Injection
→ XPATH Injection, Sensitive Data Exposure
→ Missing Function Level Access Control
→ Unvalidated Redirects and Forwards

5.API Security

→What is API, use of API
→What is endpoint
→What are HTTP methods in API
→Check request and response using postman
→Status codes in API
→What is authentication and authorization
→JWT authentication
→Types of authentications like NoAuth, Basic Auth, Bearer token, OAuth, SAML
→What is Cookie and cookie related checks
→Important security headers checks – Content security policy, XSS protection, clickjacking, Strict transport security, Insecure policy, content type options
→Cross origin resource sharing
→Intercept postman with Burp Suite
→Information disclosure through banner grabbing/Fingerprint web server
→Broken Object Level Authorization
→Broken Authentication
→Broken Object Property Level Authorization
→Unrestricted Resource Consumption
→Broken Function Level Authorization
→Unrestricted Access to Sensitive Business Flows
→Server-Side Request Forgery
→Security Misconfiguration
→Improper Inventory Management
→Unsafe Consumption of APIs

6.Windows Application Security

→What is thick client application
→Types of Thick Client Applications
→check network traffic using Thick Client
→check network traffic using Wireshark
→Data Storage and Privacy
→Network Communication
→Code Quality
→Backend API
→Injection Flaws
→Authentication Issues
→Authorization Issues
→Session Management
→Business Logic Flaws, Data Tampering

7.Mobile Application Security

→Improper Credential Usage
→Inadequate supply chain security
→Insecure Authentication/Authorization
→Insufficient Input/output validation
→Insecure Communication
→Inadequate Privacy Control
→Insufficient Binary Protection
→ Security Misconfiguration
→Insecure Data Storage
→Insufficient Cryptography

8.Network Security

→outdated software or unpatched software
→ Misconfigured firewalls/operating systems
→Unsecured network access points
→Weak Passwords and Authentication Protocols
→Unsecured Network Access Points
→Phishing and Social Engineering Attacks [Insecure incoming emails]
→Single-factor authentication
→Absence of data backups
→Removable media devices
→Lack of network segmentation
→Insufficient access controls and privilege management
→Ransomware
→Configuration errors
→DDoS attacks
→Man in the middle attacks
→Trojan Attacks